INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

GRC 103 - Week 2 Lab Assignment

Risk Assessment and Management Techniques

Lab 3A: Advanced GRC Phishing Simulation & Quantitative Risk Analysis

Name	Adeshola Oluwole
Registration Number	C1126CGRCE17211
Course	**GRC 103 Risk Assessment and Management Techniques**
Module	**Module 2 — Risk Analysis and Evaluation**
Opens	25 October 2026, 5:41 PM WAT
Due	01 November 2026, 11:59 PM WAT

1. Introduction

A GRC professional not only understand human risks but must be able to QUANTIFY it in financial terms that executives understand. This is an ultimate phishing risk analysis lab and this lab is designed to transform someone from who "knows phishing is bad" to someone who can PROVE exactly how bad phishing is with hard numbers and financial calculations.

Scenario

You are the lead GRC analyst at "GlobalTech Inc." The CISO has provided you with data from THREE different phishing simulations conducted last quarter.

Your mission is to conduct a comprehensive risk analysis that will determine next year's security budget and strategy.

2. Objectives

- Master advanced phishing metric calculations
- Learn to calculate financial risk exposure
- Conduct cost-benefit analysis for security controls
- Create executive-level risk reports with quantitative justification
- Understand statistical significance in security testing

3. Deliverables

Submit the following completed items:

1. **Completed Calculation Worksheets** from Phases 1 & 2)
2. **Risk Assessment Matrix** from Phase 3
3. **Statistical Analysis** with confidence intervals
4. **Executive Briefing** with your specific financial calculations
5. **Control Recommendation Table** with your ROI calculations

4. Lab Data Set

Campaign Results:

Campaign A: "HR Bonus Notification"

- Target Group: 100 Employees
- Emails Sent: 100
- Emails Opened: 82
- Links Clicked: 47
- Credentials Submitted: 18
- Data Entry Points: 5 (employees who also entered personal information)

Campaign B: "IT System Password Reset"

- Target Group: 250 Employees
- Emails Sent: 250
- Emails Opened: 200
- Links Clicked: 150
- Credentials Submitted: 75
- Data Entry Points: 25

Campaign C: "CEO Urgent Document Review"

- Target Group: 80 Executives & Assistants
- Emails Sent: 80
- Emails Opened: 72
- Links Clicked: 60
- Credentials Submitted: 12
- Data Entry Points: 8

Organizational Context:

- Total Employees: 2,000
- Average Employee Salary: $85,000/year
- Estimated Cost of Data Breach: $4.35 million (industry average)
- Probability of Major Breach if Credentials Stolen: 25%

PHASE 1: BASIC METRIC CALCULATIONS

Step 1: Calculate Fundamental Rates

Formula: Rate = (Number of Events / Number of Emails Sent) × 100*

Fill in the blanks

Campaign	Email Open Rate (Open / Sent) x 100	Click-Through Rate (Click / Sent) x 100	Credential Submission Rate (CS / Sent) x 100	Data Entry Rate (DER / Sent) x 100
A	(82/100) ×100 = **82%**	(47/100) ×100 = **47%**	(18/100)×100 = **18%**	(5/100)×100 = **5%**
B	(200/250) ×100 =**80%**	(150/250) ×100 =**60%**	(75/250)×100 = **30%**	(25/250)×100 = **10%**
C	(72/80) ×100 = **90%**	(60/80) ×100 = **75%**	(12/80)×100 = **15%**	(8/80)×100 = **10%**

Step 2: Calculate Efficiency Metrics

How effective is each step of the attack?

Conversion rate from open to click

Campaign	Calculation	Result	Reading
A	(47/82)×100	57.3%	Moderate
B	(150/200)×100	75.0%	High
C	(60/72)×100	83.3%	Highest: executives who opened almost always clicked

Post-click credential submission rate

Campaign	Calculation	Result	Reading
A	(18/47)×100	38.3%	Moderate
B	(75/150)×100	50.0%	Highest: the password-reset lure converts best after the click
C	(12/60)×100	20.0%	Lowest: executives were more cautious at the login page

Campaign C's executives were the most likely to click the moment they opened the email (83.3%), but only 20% of them gave up their credentials.

Campaign B had the most credential submissions per click (50%) even with the75% open to click.

Campaign A had the lowest rate open to click with 57.3%, yet 38.3% of them submitted their credentials.

PHASE 2: ADVANCED RISK QUANTIFICATION

Step 3: Calculate Organizational Risk Exposure

Scaled Risk Projection:
If these rates apply to our entire organization of 2,000 employees...

For Campaign B (most successful):

- Expected Credentials Stolen: 2,000 × (75 / 250) = **600 employees**
- Expected Data Breaches: 600 × 25% probability = **150 breaches**

Calculation:

- Campaign B Credential Rate: 75/250 = 30%
- Organization Exposure: 2,000 × 0.30 = **600 employees**
- Expected Breaches: 600 × 0.25 = **150 breach incidents**

Step 4: Financial Impact Analysis

A. Potential Financial Loss:

- Single Breach Cost: $4,350,000
- Expected Number of Breaches: 150
- Total Exposure: $4,350,000 × 150 = **$652,500,000**

B. Annualized Loss Expectancy (ALE):
ALE = Single Loss Expectancy × Annual Rate of Occurrence

- Single Loss Expectancy (SLE): $4,350,000
- Annual Rate of Occurrence (ARO): 150 expected breaches
- ALE = $4,350,000 × 150 = **$652,500,000**

Step 5: Control Effectiveness Analysis

MFA Cost-Benefit Analysis:

- Cost to Implement MFA: $45 per user × 2,000 users = **$90,000**
- MFA Effectiveness: 99.9% reduction in credential theft impact
- Risk Reduction: $652,500,000 × 0.999 = **$651,847,500**
- **ROI: ($651,847,500 - $90,000) / $90,000 = 724,175%**

Security Training Cost-Benefit:

- Training Cost: $50 per user × 2,000 users = $100,000
- Expected Effectiveness: 60% reduction in click-through rates
- New Click-Through Rate: 30% × (1-0.60) = 12%
- New Credentials Stolen: 2,000 × 0.12 = 240
- New Expected Breaches: 240 × 0.25 = 60
- New ALE: $4,350,000 × 60 = $261,000,000
- Risk Reduction: $652,500,000 - $261,000,000 = $391,500,000
- ROI: ($391,500,000 - $100,000) / $100,000 = 391,400%

PHASE 3: COMPREHENSIVE RISK ASSESSMENT

Step 6: Complete Risk Assessment Matrix

Campaign	Overall Risk Score	Financial Exposure	Priority Level	Recommended Action
A	HIGH	$391,500,000	2	Enhanced Training plus MFA for all accounts
B	**CRITICAL**	**$652,500,000**	**1**	**IMMEDIATE MFA with password-reset and credential-handling controls**
C	HIGH	$326,250,000	2	Executive Training, plus phishing-resistant MFA for privileged accounts

Calculations for the table

- **Campaign A:** (18/100) × 2,000 = 360 employees → 360 × 0.25 = 90 breaches → 90 × $4,350,000 = $391,500,000
- **Campaign B:** (75/250) × 2,000 = 600 employees → 600 × 0.25 = 150 breaches → 150 × $4,350,000 = $652,500,000
- **Campaign C:** (12/80) × 2,000 = 300 employees → 300 × 0.25 = 75 breaches → 75 × $4,350,000 = $326,250,000

Rationale for priority levels. Campaign B has the highest credential rate and the largest exposure, so it is Priority 1. Campaigns A and C share Priority 2. Campaign C has the lower dollar exposure, but it targets executives and assistants whose accounts typically carry privileged access, which justifies the same priority level as A. It is important to note that Campaign C's exposure was estimated using a sample of 80 executives and applied to the entire company. Therefore, the figure is only an estimate and may not reflect the exact level of exposure across the company (see section 6).

Step 7: Statistical Analysis with Confidence Intervals

Calculate Confidence Intervals (95% Confidence):
Formula: $p \pm 1.96 \times \sqrt{[p(1-p)/n]}$*

For Campaign B Credential Rate (30%):

- p = 0.30, n = 250
- Margin of Error = $1.96 \times \sqrt{[0.30(1-0.30)/250]} = 1.96 \times \sqrt{(0.21/250)} = 1.96 \times \sqrt{0.00084} = 1.96 \times 0.029 = 0.057$
- **True Rate Range: 24.3% to 35.7%**

Calculate for Campaign A: (Credential Rate of 18%)

- p = 0.18, n = 100
- Margin of Error = $1.96 \times \sqrt{[0.18(1-0.18)/100]}$ = ?
- True Rate Range: ?% to ?%

Campaign A (worked calculation)

- p = 0.18, n = 100
- Margin of error = $1.96 \times \sqrt{[0.18 \times 0.82 / 100]} = 1.96 \times \sqrt{0.001476} = 1.96 \times 0.0384 = 0.0753$
- True rate range: **10.5% to 25.5%**

And to also Calculate for Campaign C (Credential Rate of 15%):

- p = 0.15, n = 80
- Margin of Error = 1.96 × √[0.15 × (1-0.15) / 80] = 1.96 × √ 0.1275 /80 = 1.96 × √0.00159375 = 0.03992 = 0.07824
- True range = 0.15 – 0.07824 = 0.07176 , 0.15 + 0.07824 = 0.22824
- True Rate Range: 7.18% appx 7.2% to 22.82%

All campaigns

Campaign	p	n	Margin of Error	95% CI	Interpretation
A	0.18	100	± 7.5 pts	10.5% – 25.5%	Wide interval: small sample
B	0.30	250	± 5.7 pts	24.3% – 35.7%	Narrowest: largest sample
C	0.15	80	± 7.8 pts	7.2% – 22.8%	Widest: smallest sample
All combined	0.244	430	± 4.1 pts	20.4% – 28.5%	Pooled: 105 / 430 submitted

Are the differences between campaigns real? (two-proportion z-test)

Comparison	z	p-value	Conclusion at 95% confidence
A vs B	2.30	0.022	Significant: B really does harvest more credentials than A, even though the intervals overlap slightly
B vs C	2.65	0.008	Significant: B is clearly more effective than C
A vs C	0.54	0.59	Not significant: A and C cannot be reliably distinguished

Effect on the financial estimate. Applying Campaign B's confidence interval to the lab's model gives an ALE range of about $529 million (24.3% rate → about 122 breaches) to $776 million (35.7% rate → about 178 breaches), around the $652.5 million point estimate. The sample sizes are modest, so the point estimates will be presented to the board as ranges. The test also supports the priority order: B is statistically the worst campaign, while A and C are statistically tied.

PHASE 4: EXECUTIVE REPORTING

Step 8: Comprehensive Executive Briefing

To: Board of Directors, CISO, CFO
From: GRC Risk Analysis Team, GlobalTech Inc.
Date: 30th October 2026
Subject: CRITICAL: Quantitative Phishing Risk Assessment & $652M Exposure

1. Executive Summary

Three phishing simulation campaigns carried out last quarter show that GlobalTech employees are still at risk of falling for phishing attacks and giving away their login details. Out of 430 simulated emails, 105 recipients (24.4%) submitted their credentials.

The IT System Password Reset campaign had the highest success rate, with 30% of recipients submitting their credentials. This also means that half of the employees who clicked the email went on to share their login details.

If these results are applied to GlobalTech's 2,000 employees, about 600 accounts could be at risk. Using the industry-average data breach cost of $4.35 million and an estimated 25% chance of a breach from each compromised credential, the standard financial model gives an Annualized Loss Expectancy (ALE) of $652.5 million.

However, because this model assumes a very high number of security incidents, we have also included a more conservative estimate of $8.7 million, based on two breaches per year. Even with the lower estimate, the recommended security improvements would provide significant financial benefits.

We therefore recommend investing $490,000 in security improvements, with enterprise-wide Multi-Factor Authentication (MFA) as the main priority.

2. Key Quantitative Findings:

Risk Metric	Standard Model	Conservative Scenerio
Overall credential theft rate (pooled, 105/430)	24.4% (95% CI 20.4%–28.5%)	24.4%
Highest campaign credential rate (B)	30% (95% CI 24.3%–35.7%)	30%
Expected breaches per year (ARO)	150	2
Single Loss Expectancy (SLE)	$4,350,000	$4,350,000
Annualized Loss Expectancy (ALE)	**$652,500,000**	**$8,700,000**

Risk Metric	Standard Model	Conservative Scenerio
Per-employee risk (ALE ÷ 2,000)	$326,250	$4,350
MFA implementation ROI	724,175%	9,557%

3. Detailed Financial Analysis:

Current State Risk:

- Annualized Loss Expectancy: **$652,500,000**

  600 compromised accounts × 25% = 150 breaches; 150 × $4,350,000 = $652,500,000 ALE.

- Probability of Major Breach: **93.75%** (150 expected breaches)

  Conservative scenario: 2 breaches × $4,350,000 = $8,700,000 ALE.

- Per-Employee Risk: **$326,250**

  Likelihood: With 600 compromised accounts each carrying a 25% chance of leading to a breach, the probability of at least one major breach is effectively certain (1 − 0.75^600 ≈ 100%).

Proposed Security Investment Portfolio:

Control	Cost	Risk Reduction (Std.)	ROI (Std.)	ROI (Conservative)	Priority
MFA Implementation	$90,000	$651,847,500	724,175%	9,557%	1
Enhanced Training	$100,000	$391,500,000	391,400%	5,120%	2
Email Filtering	$50,000	$130,500,000	260,900%	3,380%	3

Full calculations are in Section 5.

4. Strategic Recommendations:

Immediate actions (Q1)

✓ Implement MFA enterprise-wide: $90,000. Priority 1; it addresses the exact failure shown in Campaign B, since a stolen password alone no longer grants access.

- ✓ Launch a targeted phishing simulation program: $25,000. This gives measurable, repeatable data on improvement.
- ✓ Conduct emergency security awareness training: $100,000. Include executive-specific content, given Campaign C's 75% click rate.

Strategic initiatives (Next fiscal year)

- ✓ Deploy an advanced email security gateway: $50,000.
- ✓ Establish continuous security monitoring: $150,000.
- ✓ Implement security behavior analytics: $75,000.

5. Expected Risk Posture After Controls:

Planning assumption: the combined program reduces risk by 90%. This is deliberately more cautious than the 99.9% MFA effectiveness figure, because no control set is perfect.

Metric	Current	With Controls	Reduction
Credential theft rate (pooled)	24.4%	2.4%	90%
Expected breaches / yr (standard)	150	15	90%
ALE (standard model)	$652,500,000	$65,250,000	90%
ALE (conservative scenario)	$8,700,000	$870,000	90%

Program Economics	Standard Model	Conservative
Total investment required	$490,000	$490,000
Total risk reduction (90% of ALE)	$587,250,000	$7,830,000
Net financial benefit	**$586,760,000**	**$7,340,000**
Program ROI	119,747%	1,498%

Decision requested: Approve the $490,000 program, with MFA rollout beginning immediately. Even under the conservative scenario, the program returns about $15 for every $1 spent.

5. Control Recommendation Table with ROI Calculations

ROI = (Risk Reduction − Cost) ÷ Cost × 100. Risk Reduction = ALE × Effectiveness. Net Benefit = Risk Reduction − Cost.

A. Standard model (ALE = $652,500,000)

Control	Cost	Effectiveness	Risk Reduction	Net Benefit	ROI	Priority
MFA	$90,000	99.9%	$651,847,500	$651,757,500	724,175%	**1**
Enhanced Training	$100,000	60%	$391,500,000	$391,400,000	391,400%	**2**
Email Filtering	$50,000	20%	$130,500,000	$130,450,000	260,900%	**3**

- **MFA:** $652,500,000 × 0.999 = $651,847,500; ($651,847,500 − $90,000) ÷ $90,000 = 7,241.75 → 724,175%
- **Training:** $652,500,000 × 0.60 = $391,500,000; ($391,500,000 − $100,000) ÷ $100,000 = 3,914 → 391,400%
- **Email filtering:** $652,500,000 × 0.20 = $130,500,000; ($130,500,000 − $50,000) ÷ $50,000 = 2,609 → 260,900%

B. Conservative scenario (ALE = $8,700,000; 2 breaches per year)

Control	Cost	Effectiveness	Risk Reduction	Net Benefit	ROI	Priority
MFA	$90,000	99.9%	$8,691,300	$8,601,300	9,557%	**1**
Enhanced Training	$100,000	60%	$5,220,000	$5,120,000	5,120%	**2**
Email Filtering	$50,000	20%	$1,740,000	$1,690,000	3,380%	**3**

- **MFA:** $8,700,000 × 0.999 = $8,691,300; ($8,691,300 − $90,000) ÷ $90,000 = 95.57 → 9,557%
- **Training:** $8,700,000 × 0.60 = $5,220,000; ($5,220,000 − $100,000) ÷ $100,000 = 51.2 → 5,120%
- **Email filtering:** $8,700,000 × 0.20 = $1,740,000; ($1,740,000 − $50,000) ÷ $50,000 = 33.8 → 3,380%

Conclusion. The priority order (MFA, then training, then email filtering) is the same in both scenarios, so the recommendation does not depend on the ARO assumption. MFA delivers the most risk reduction for the least cost, training covers the human factor MFA cannot, and email filtering reduces how many phishing messages reach inboxes at all. The $25,000 simulation program, $150,000 monitoring and $75,000 analytics items are recommended in the briefing but are not ranked here because no effectiveness figures were supplied for them.

BONUS CHALLENGE:

Calculate the break-even point for our security investments. If we invest $490,000 in controls, how many breaches must we prevent to justify the cost?

Hint: $490,000 / $4,350,000 per breach = ? breaches*

To calculate the break-even point, we will calculate Total investment divided by Cost per breach.

So we will have $490,000 / $4,350,000 per breach = 0.1126 breaches

This means that preventing a single breach would save an estimated $4.35 million, which is more than enough to cover the $490,000 security investment.